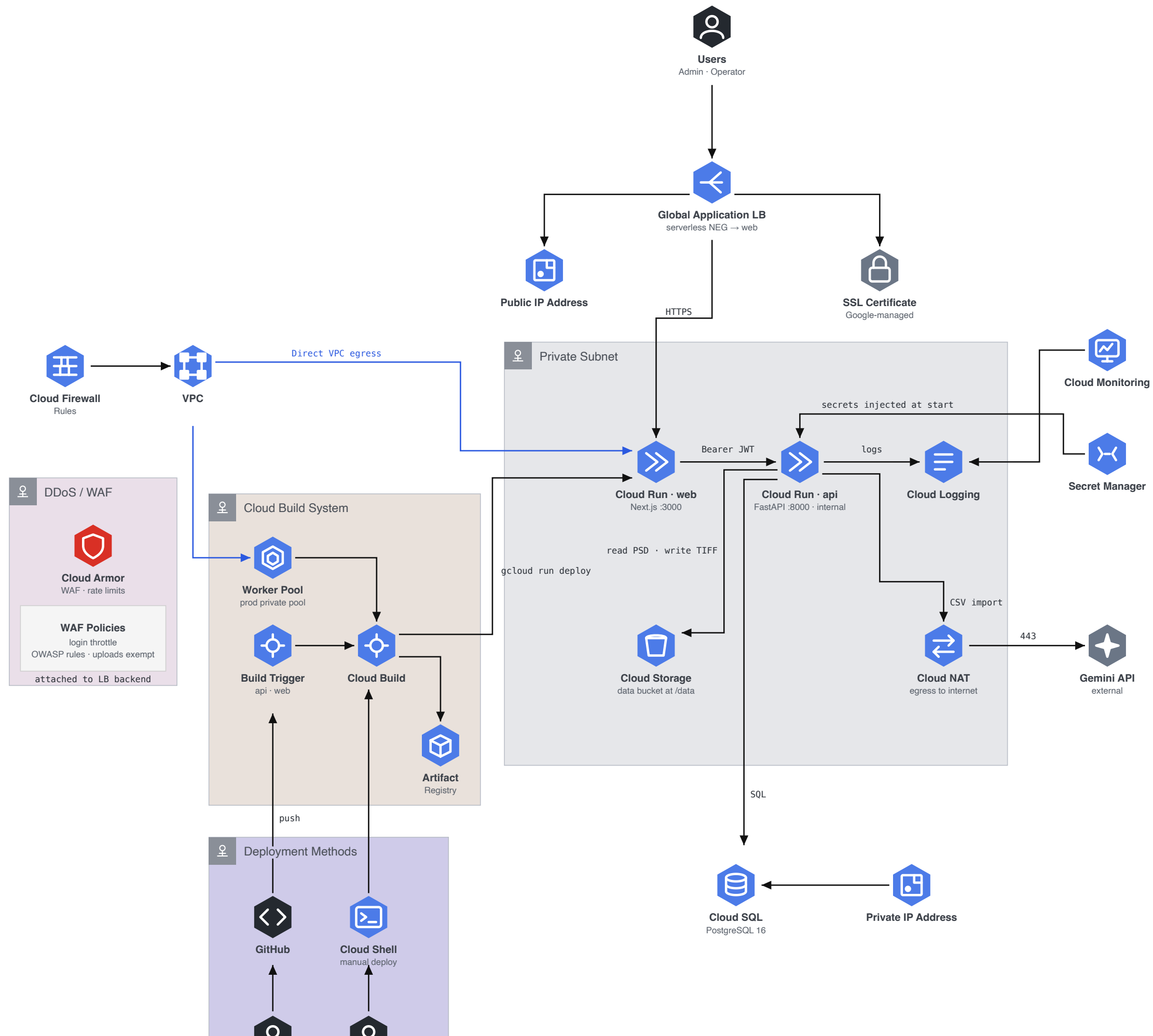


PrintFlow on Google Cloud

Infrastructure request for the cloud team. It follows the same pattern as the existing jiab and thumbs-up projects: Cloud Run behind a global HTTPS load balancer with Cloud Armor, Artifact Registry, Secret Manager and Cloud Build.

asia-south1	2 projects: test, prod	2 Cloud Run services	Cloud SQL Postgres 16	Cloud Storage at /data
-------------	------------------------	----------------------	-----------------------	------------------------

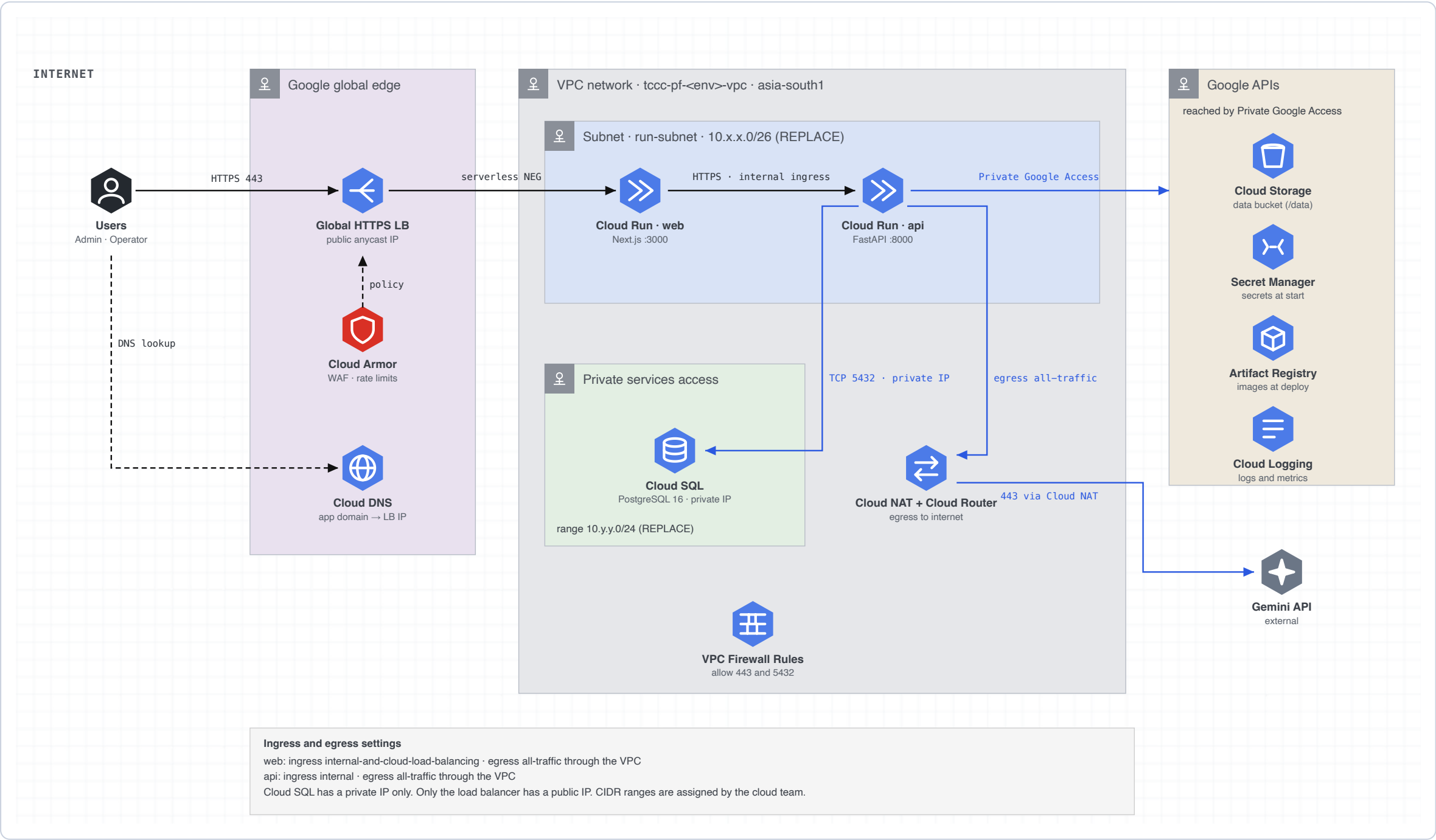
Architecture diagram





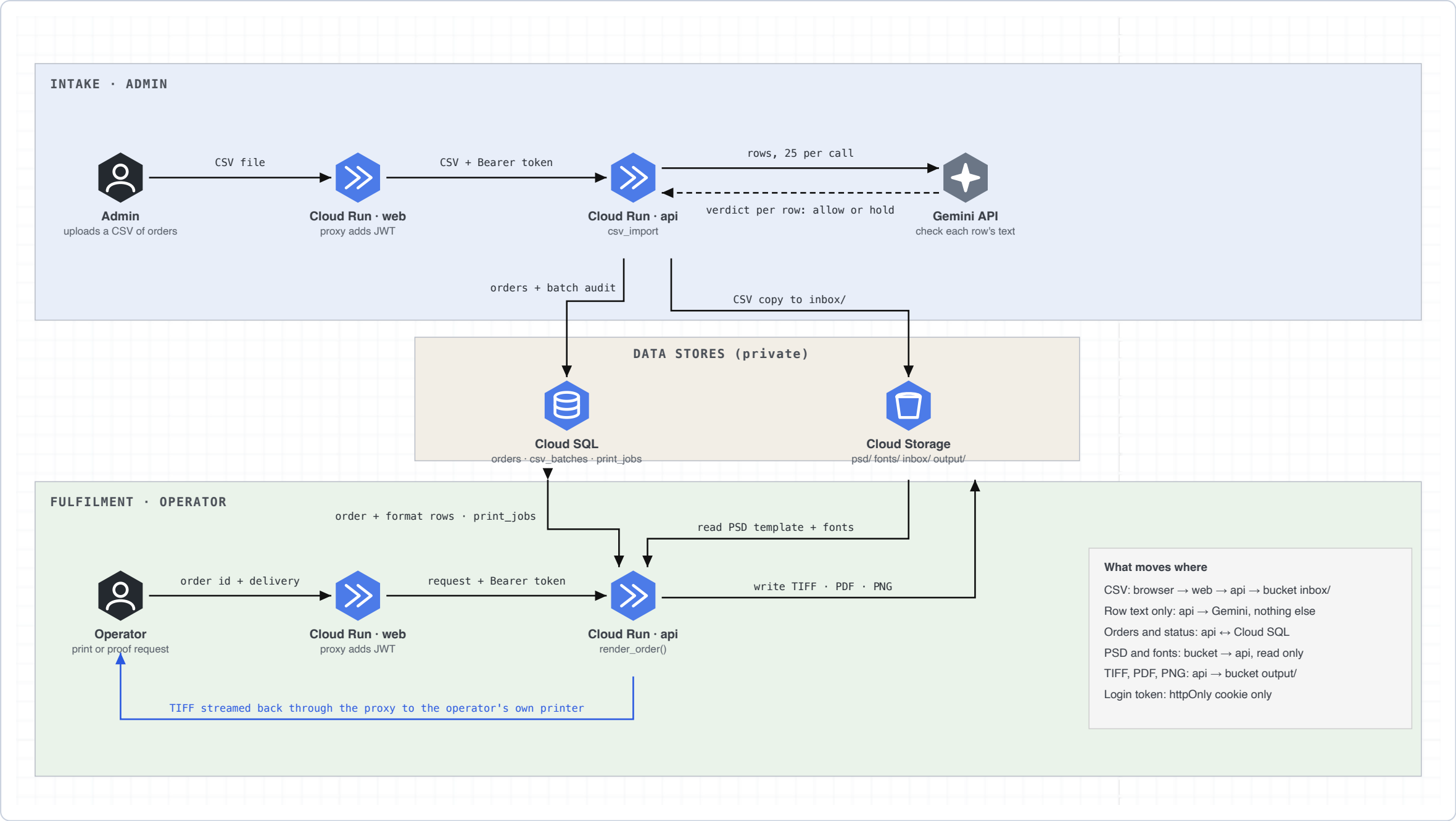
Network and deployment view. The shaded zones group what sits in the private subnet, the CI/CD system, the WAF layer and the ways code gets deployed. Blue lines are network paths, black lines are requests and deploy actions. Icons are simplified in the Google Cloud style.

Network topology



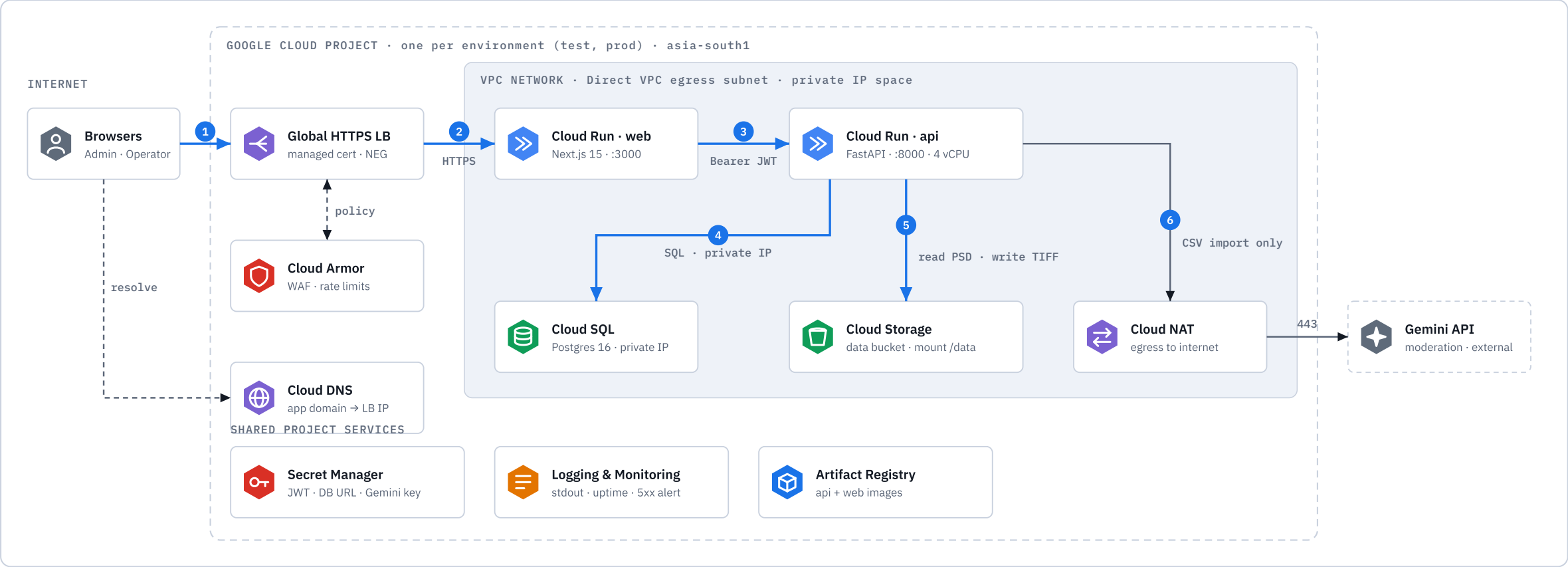
Only the load balancer has a public IP. Cloud Run web and api reach the VPC through Direct VPC egress. Cloud SQL uses private services access, outbound calls to Gemini go through Cloud NAT, and Cloud Storage and Secret Manager are reached over Private Google Access. Subnet and peering ranges are for the cloud team to assign.

Data flow



Admins bring orders in as CSV, and operators turn an order into a print-ready file. The arrows name the data that moves. Only the text of each CSV row leaves Google Cloud, when it is sent to Gemini for checking.

Request flow



Only the web service is public, and only through the load balancer. The API has internal ingress and is reached by the web service over the VPC. Solid blue is the request path, grey is egress, dashed lines are DNS, policy and admin tasks. Icons are simplified in the Google Cloud palette; swap in the official icon set when this goes into a design file.

- 1 Browser to load balancer.** Cloud DNS resolves the app domain to the LB. Cloud Armor checks rate and WAF rules, TLS ends at the LB.
- 2 Load balancer to web.** A serverless NEG sends traffic to Cloud Run web (Next.js). Login sets an httpOnly cookie that holds the JWT.
- 3 Web to API.** The proxy route adds the Bearer token and calls the API over Direct VPC egress. The API accepts only internal traffic.
- 4 API to Cloud SQL.** SQLAlchemy connects to the private IP. Six tables, schema created on start.
- 5 API to Cloud Storage.** The render reads PSD and font templates and writes the TIFF, PDF and PNG to /data/output. Downloads stream back through the web proxy to the operator's own printer.
- 6 API to Gemini (CSV import only).** Moderation calls go out through Cloud NAT, 25 rows per call, 4 in parallel.

Services to provision

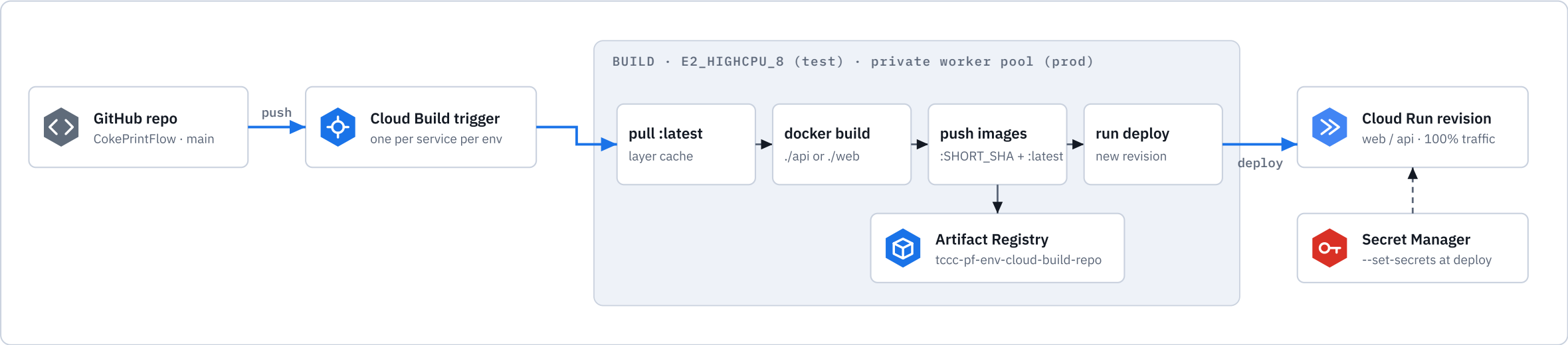
Sized for up to 1 lakh users. Peak concurrent renders is still to be confirmed with a load test. Per environment, in separate test and prod projects. Names are proposed and follow `tccc-pf-<env>-....`

SERVICE	PURPOSE	CONFIGURATION
Cloud Run · web	Next.js UI and the API proxy	gen2, port 3000, 1 vCPU, 1536 MiB, min 1, max 3 (prod 5), timeout 600s, ingress internal-and-cloud-load-balancing

SERVICE	PURPOSE	CONFIGURATION
Cloud Run · api	FastAPI, PSD rendering	gen2, port 8000, 4 vCPU, 8 GiB, CPU boost, min 1, max 3 (prod 10), concurrency 4, timeout 600s, ingress internal, Cloud Storage bucket mounted at /data
Cloud SQL	PostgreSQL 16	Private IP only. Test 1 vCPU / 3.75 GB. Prod 2 vCPU / 7.5 GB, HA, backups, PITR.
Cloud Storage (data bucket)	Shared /data: psd, fonts, inbox, output	One regional bucket in asia-south1, mounted through GCS FUSE with implicit-dirs and a short metadata cache. Container disks are lost on restart, so every file lives here.
VPC, Cloud Router, Cloud NAT	Private connectivity and outbound internet	Run subnet /26 or larger, Private Google Access on. NAT is needed for the Gemini API.
Global HTTPS LB	Public entry point	Serverless NEG to web, managed certificate, backend timeout 600s , HTTP to HTTPS redirect
Cloud Armor	WAF and rate limits	Attach to the web backend service. Rules are in the next section. Uploads of PSD, font and CSV skip the managed WAF rules.
Cloud DNS	App domain	A record to the LB IP. Domain to be confirmed.
Artifact Registry	Images	tccc-pf-<env>-cloud-build-repo, tags :SHORT_SHA and :latest
Cloud Build	CI/CD	Two triggers per environment. Prod uses a private worker pool.
Secret Manager	Runtime secrets	Secret name equals env var name, mapped with --set-secrets
Bucket lifecycle rule	Cleanup of rendered files	Delete objects under output/ after N days (proposal: 30)
Logging and Monitoring	Operations	Uptime check on /login, alert on API 5xx

Not needed: Pub/Sub, Memorystore, Cloud Scheduler, Strapi, GKE, Vertex AI. The app has no queue, no cache layer and no CMS.

Build and deploy



Each service has its own Cloud Build file, in the same five-step shape as thumbs-up-be. The web build looks up the API service URL and injects it as API_BASE_URL, so the API must be deployed first.

FILE	ENVIRONMENT	BUILDS	BUILDER
cloudbuild-api.yaml	test	./api to tccc-pf-test-cloudrun-api	E2_HIGHCPU_8
cloudbuild-web.yaml	test	./web to tccc-pf-test-cloudrun-web	E2_HIGHCPU_8
cloudbuild-prod-api.yaml	prod	./api to tccc-pf-prod-cloudrun-api	private worker pool
cloudbuild-prod-web.yaml	prod	./web to tccc-pf-prod-cloudrun-web	private worker pool

Values the cloud team fills in are marked REPLACE: project id, network, subnet, data bucket name, app URL, and the project id inside workerPool. Trigger branch mapping is not stored in the jiab or thumbs-up repos, so copy it from the existing triggers in the console.

Cloud Armor rules

Created by infra/cloud-armor.sh and attached to the web backend service. Uploads of PSD, font and CSV are exempt from managed WAF rules, because binary and quoted content causes false positives. They are still rate-limited.

PRIORITY	MATCH	ACTION	WHY
1000	POST /api/auth/login	Throttle 10 per minute per IP, then 429	Brute-force protection
1100	POST /api/proxy/print-formats/upload-psd, /print-formats/upload-font, /csv/upload	Throttle 30 per minute per IP, then 429. Allowed without managed WAF inspection.	Large binary PSDs and CSVs with quotes and symbols would otherwise trip WAF rules
3000 to 3060	All other requests	OWASP sets at sensitivity 1, deny 403: sqli, xss, lfi, rfi, rce, protocol attack, scanner detection	Standard attack protection
Default	Any	Allow	

The exemption is safe because every proxied route needs a valid JWT, PSD and font files are parsed and never executed, CSV rows are validated and moderated, and the throttle still limits abuse. Managed rules start in preview: test a large PSD, a font and a CSV with special characters, check the load balancer logs for would-be denials, then enforce. Cloud Run's 32 MiB request limit is separate and still applies.

Secrets and configuration

NAME	KIND	USED BY	NOTES
PRINTFLOW_JWT_SECRET	Secret	api	HS256 signing key, identical on every instance. The code default is for development only.
PRINTFLOW_DATABASE_URL	Secret	api	postgresql+psycopg://printflow:...@<private-ip>:5432/printflow
GEMINI_API_KEY	Secret	api	Without it, every imported row is held for review.

NAME	KIND	USED BY	NOTES
PRINTFLOW_PRINTING_ENABLED	Env	api	false. Cloud Run has no CUPS. Operators use DOWNLOAD or PROOF delivery.
PRINTFLOW_TIFF_COLORSPACE	Env	api	CMYK
PRINTFLOW_MODERATION_ENABLED	Env	api	true
PRINTFLOW_CORS_ORIGINS	Env	api	Public web URL
API_BASE_URL	Env	web	Resolved from the deployed API service by the pipeline

Runtime service account gets Secret Manager accessor, log writer, and object admin on the data bucket only. It does not need Cloud SQL client or Pub/Sub roles, because the database is reached by private IP.

Decisions and risks for the cloud team

32 MiB upload limit

Cloud Run caps a request at 32 MiB and the web proxy buffers the body. Real PSDs can be tens of MB. Large PSDs are copied straight into the data bucket under psd/ until the app supports signed-URL uploads.

Cloud Storage mount behaviour

GCS FUSE holds a file in instance memory until it closes, so a large TIFF counts against the 8 GiB, and open and save are slower than local disk. Load test with the largest real PSD. Fallback is Filestore.

Long requests

Render and CSV import run inside the request. Cloud Run, the LB backend and any proxy must all allow 600s. Render time has not been measured, so load test before prod.

DB connection limit

Each API instance keeps its own pool, and small Cloud SQL tiers allow roughly 100 to 200 connections. Cap the pool so max instances times pool size stays under the limit, or use a larger tier.

Memory sizing

8 GiB with concurrency 4 is a starting point, not a measured figure. Each render holds large image arrays.

Cloud Armor false positives

Upload routes are exempt from managed rules. Other JSON routes that carry label text could still trip one, so the managed rules start in preview.

Gemini dependency

Moderation needs outbound internet through Cloud NAT and an API key. Staying inside GCP would need a move to Vertex AI in the code.

First boot race

The API creates the schema on start. Keep max instances at 1 for the first revision, then raise it.

Output growth

Rendered files in /data/output are never deleted by the app. A lifecycle rule on the bucket deletes them after N days.

Cookie check: the web app sets the Secure flag from the request scheme. After go-live, confirm that Next.js sees https behind the load balancer.

Ticket checklist

- ☐ Test and prod projects, APIs enabled
- ☐ VPC, run subnet, private services range, Cloud Router, Cloud NAT
- ☐ Cloud SQL PostgreSQL 16 on private IP, database and user

- ☐ Data bucket with prefixes, lifecycle rule and bucket-level access for the runtime service account
- ☐ Secrets created in Secret Manager
- ☐ HTTPS LB with serverless NEG, certificate, 600s backend timeout
- ☐ Uptime check and 5xx alert
- ☐ Artifact Registry repo
- ☐ Prod private worker pool
- ☐ Cloud Armor `infra/cloud-armor.sh`, tested in preview, then enforced
- ☐ Handover: data bucket name, network and subnet names, project ids, domain
- ☐ Runtime and Cloud Build service accounts with IAM roles
- ☐ Cloud Build triggers: api and web, test and prod
- ☐ Cloud DNS record